



CY201: Cyber Security Principles and Concepts

Course Instructor: Sir Ahmed Nawaz

Assignment # 1

Name: Sohaib Bin Tausif

Reg #: 2024595

Faculty: Cyber Security

First Lab: Unprotected Admin Functionality

Lab Task:

This lab has an unprotected admin panel. Solve the lab by deleting the user carlos.

Solution:

For the first lab we had to add /administrator-panel to the URL to get access for the admin panel then delete the user, carlos.

Second lab: Unprotected admin functionality with unpredictable URL

Lab Task:

This lab has an unprotected admin panel. It's located at an unpredictable location, but the location is disclosed somewhere in the application. Solve the lab by accessing the admin panel and using it to delete the user carlos.

Solution:

In this lab I used inspect or page source to view lab home page where we have to find the vulnerability where we have to find admin panel URL then gain the full access and delete the user carlos.

Third Lab: User role controlled by request parameter

Lab Task:

This lab has an admin panel at /admin, which identifies administrators using a forgeable cookie. Solve the lab by accessing the admin panel and using it to delete the user carlos.

Solution:

In this Lab we have to find the cookies where 'admin=false' after logging into the account, after modifying admin=false to 'admin=true' we get the access to the admin panel and delete the user carlos.

Fourth Lab: User role can be modified in user profile

Lab Task:

This lab has an admin panel at /admin. It's only accessible to logged-in users with a roleid of 2. Solve the lab by accessing the admin panel and using it to delete the user carlos.

Solution:

Log in using the supplied credentials and access your account page. Update the email address associated with your account. Send the response packet to the repeater in Burp Proxy then observe that the response packet contains your role ID and modify it to "roleid:2" and resend it. Search to "/admin" and delete carlos.

Fifth Lab: URL-based access control can be circumvented**Lab Task:**

This website has an unauthenticated admin panel at /admin, but a front-end system has been configured to block external access to that path. However, the back-end application is built on a framework that supports the X-Original-URL header.

Solution:

Attempting to load the /admin page will result in a block. Send the Burp Repeater this request. In the request line, change the URL to / and include the HTTP header "X-Original-URL: /invalid." Note that the application gives you a "not found" message. This shows that the X-Original-URL header is being used by the back-end system to process the URL. Modify the X-Original URL header to read /admin. The admin page is now available to you. In order to remove Carlos, we alter the X-Original-URL route to /admin/delete and add "?username=carlos" to the actual query string at the top.

Sixth Lab: Method-based access control can be circumvented**Lab Task:**

This lab implements access controls based partly on the HTTP method of requests. You can familiarize yourself with the admin panel by logging in using the credentials "administrator:admin". To solve the lab, log in using the credentials "wiener:peter" and exploit the flawed access controls to promote yourself to become an administrator.

Solution:

First we logged in using the given credentials then go to the admin interface, send the Burp Repeater an HTTP request, and promote Carlos. Get out now, then use the non-admin credentials to get back in. By copying the non-admin user's session cookie into the current Burp Repeater request, you can try to promote Wiener with them. However, you'll see that the answer reads "Unauthorized." Now, right-click and choose "Change request method" to change the method to "GET." Send the request again after changing the username parameter to your own username then after this the user gets promotion.

Seventh Lab: User ID controlled by request parameter

Lab Task:

This lab has a horizontal privilege escalation vulnerability on the user account page. To solve the lab, obtain the API key for the user carlos and submit it as the solution. You can log in to your own account using the following credentials: wiener:peter.

Solution:

First, log in using the credentials wiener:peter. After logging in, navigate to the account page and observe that the URL contains a parameter such as ?id=wiener. Change the id parameter value to carlos in the URL. The application returns carlos's account page including their API key. Copy and submit the API key to solve the lab. This demonstrates horizontal privilege escalation where one user can access another user's resources simply by modifying an ID parameter in the request.

Eighth Lab: User ID controlled by request parameter, with unpredictable user IDs

Lab Task:

This lab has a horizontal privilege escalation vulnerability on the user account page, but identifies users with GUIDs. To solve the lab, find the GUID for carlos, then submit his API key as the solution. You can log in to your own account using the following credentials: wiener:peter.

Solution:

Log in as wiener:peter and browse the application. Look through blog posts or other user-generated content and find a post authored by carlos. Inspect the link to carlos's profile to extract the GUID used as his user identifier. Then navigate to the account page and replace the GUID in the URL with carlos's GUID. This reveals carlos's account page along with his API key. Copy and submit the API key as the solution. Even though the identifier is a GUID (seemingly unpredictable), it was exposed through the application's own content.

Ninth Lab: User ID controlled by request parameter with data leakage in redirect

Lab Task:

This lab contains an access control vulnerability where sensitive information is leaked in the body of a redirect response. To solve the lab, obtain the API key for the user carlos and submit it as the solution. You can log in to your own account using the following credentials: wiener:peter.

Solution:

Log in as wiener:peter. Navigate to your account page and observe the URL parameter containing your user ID. Change the user ID in the URL to carlos. The server issues a redirect response (302), however the body of the redirect response contains the page content including carlos's API key before the browser follows the redirect. Use Burp Suite to intercept the redirect response and read the API key from the response body before the redirection happens. Submit the API key to solve the lab.

Tenth Lab: User ID controlled by request parameter with password disclosure**Lab Task:**

This lab has user account pages that contain the current user's password, pre-filled in a masked input. To solve the lab, retrieve the administrator's password, then use it to delete the user carlos. You can log in to your own account using the following credentials: wiener:peter.

Solution:

Log in as wiener:peter and go to the account page. Observe that the page contains a masked password input field that is pre-filled with the logged-in user's password. Now change the user ID parameter in the URL to administrator. The administrator's account page loads and the password input is pre-filled with the administrator's actual password. Use browser developer tools or Burp Suite to read the value attribute of the password field. Log out and log back in as administrator using the retrieved password. Then navigate to the admin panel and delete the user carlos to solve the lab.

Eleventh Lab: Insecure Direct Object References (IDOR)**Lab Task:**

This lab stores user chat logs directly on the server's file system, and retrieves them using static URLs. Solve the lab by finding the password for the user carlos, and logging into their account. You can log in to your own account using the following credentials: wiener:peter.

Solution:

Log in as wiener:peter and open the live chat feature. Send a message and then use the "View transcript" option to download the chat transcript. Observe that the transcript is downloaded as a file with a numeric filename such as 2.txt. Modify the filename in the download URL to 1.txt to fetch another user's transcript. Open the downloaded transcript and look through its content. Carlos's transcript reveals his password. Use this password to log in as carlos and solve the lab. This is a classic IDOR vulnerability where file access is controlled only by a predictable identifier.

Twelfth Lab: Multi-step process with no access control on one step

Lab Task:

This lab has an admin panel with a flawed multi-step process for changing a user's role. You can familiarize yourself with the admin panel by logging in using the credentials administrator:admin. To solve the lab, log in using the credentials wiener:peter and exploit the flawed access controls to promote yourself to become an administrator.

Solution:

First, log in as administrator:admin and use the admin panel to promote a user. Observe using Burp Suite that the promotion process involves two steps: a form submission and a confirmation step. Note the HTTP requests for both steps, particularly the confirmation request and its parameters. Log out and log in as wiener:peter. Replay the confirmation step request directly using Burp Repeater, substituting wiener as the username in the request body. Because the application only enforces access control on the first step of the process and not on the confirmation step, the request succeeds and wiener is promoted to administrator. This demonstrates how multi-step workflows can have incomplete access control when only some steps are protected.